

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for E-Commerce

Session : Semester B 2001/02

Time allowed : 2 hours

This paper has **FOUR** pages (including this cover page).

1. This paper consists of SIX questions. All questions carry equal marks.
 2. Answer **ANY FOUR** questions.
 3. If more than 4 questions are attempted, all answers will be marked and the BEST 4 answers selected.
-

Materials, aids & instruments permitted to be used during examination:

Approved calculator

1.
 - a) Discuss the use of RSA to exchange DES keys in the Secure Electronic Transaction Protocol.
[5 marks]
 - b) Describe the Diffie Hellman Key Exchange protocol and potential attacks on this protocol.
[5 marks]
 - c) Alice and Bob decide to exchange a session key using the Diffie Hellman Technique. They share a modulus 13 and parameter 7. Alice selects random number 9 and Bob selects the number 3. Compute the secret key exchanged, showing both Alice's and Bob's computations
[10 marks]
 - d) Why would the parameter 5 have been a poor choice?
[5 marks]
2. Discuss briefly any **ten (10)** of the following topics
 - a) Bump in the Wire (BITW)
[2.5 marks]
 - b) CRL
[2.5 marks]
 - c) Registration Authority
[2.5 marks]
 - d) First Virtual Bank
[2.5 marks]
 - e) Basic Encoding Rules (BER)
[2.5 marks]
 - f) Message Authentication Code (MAC)
[2.5 marks]
 - g) Authentication Header (AH)
[2.5 marks]
 - h) Branding Trust
[2.5 marks]
 - i) Spoofers
[2.5 marks]
 - j) P Boxes
[2.5 marks]
 - k) Fermat's Theorem
[2.5 marks]
 - l) Dynamic Filters in Firewalls
[2.5 marks]

3. You are an employer who decides to use PKI for employee access control to your information systems. Discuss:
- The operation of such a system. [13 marks]
 - The precautions necessary when the root self signed certificate is installed, and updated, in the authentication servers. [2 marks]
 - Your company has now bought a subsidiary company, which also uses PKI for employee access control, but this subsidiary company has obtained its certificates from another CA, not recognised by your root certificates. You want both set of employees to access all the authentication servers in both companies – with minimal cost and disruption. How could you achieve this? [7 marks]
 - Both sets of the employee had critical extension fields specifying the policies for certificate usage. Discuss the problems that could arise from these fields and the means that could be employed to overcome them. [3 marks]
4. a) Describe the DES Cipher Block Chaining Mode. [4 marks]
- b) Two users employing the DES Cipher Block Chaining Mode agree that the sender will transmit a 64-bit Initialisation Vector, in plaintext, before the encrypted data. An attacker intercepts this block and changes the first bit of the IV. The sender then transmits the ciphertext, which is decrypted by the receiver, using the corrupted IV. What will be the effect on the decrypted message at the receiver's end? [3 marks]
- c) Describe briefly the operations AddRoundKey, ByteSub, ShiftRow and Mix Column in the Rijndael Cipher. [10 Marks]
- d) Given the transform
- | | | | |
|----|-----------------|----|---|
| b0 | 1 0 0 0 1 1 1 1 | c0 | 1 |
| b1 | 1 1 0 0 0 1 1 1 | c1 | 1 |
| b2 | 1 1 1 0 0 0 1 1 | c2 | 0 |
| b3 | 1 1 1 1 0 0 0 1 | c3 | 0 |
| b4 | 1 1 1 1 1 0 0 0 | c4 | 0 |
| b5 | 0 1 1 1 1 1 0 0 | c5 | 1 |
| b6 | 0 0 1 1 1 1 1 0 | c6 | 1 |
| b7 | 0 0 0 1 1 1 1 1 | c7 | 0 |
- Find the **first bit only** (b0) of Rijndael Bytesub operation for the input byte {0 1}. Show all your calculations. [8 marks]

- 4 -

5 Discuss any **five (5)** of the following topics.

- a) ISAKMP and Oakley Key Exchange [5 marks]
- b) Electronic cash [5 marks]
- c) Dual Signatures [5 marks]
- d) IPSec Tunnel Mode [5 marks]
- e) Identrus [5 marks]
- f) X.509 Digital Certificate [5 Marks]
- g) RSA [5 Marks]

6. Your employer is concerned about the security of company data on the organization's network, and in particular on the proposal to link that network with two of its suppliers networks over WANs. Most of the data transmitted on the internal and external networks is routine but some of it is highly confidential and often has financial implications.

He is also concerned that hackers will attempt to access the internal networks when they are connected to the WAN.

Write a report for your manager outlining some of the approaches he could take to minimize these security problems.

[25 marks]

- END -